

CallTrove sign-up and billing

Bugs found and how they were fixed | October 9 and 10, 2026

The short version

- Over these two days we built self-serve sign-up: pick a plan, confirm your email, pay, and only then does the account exist. We also built usage billing for transcripts and AI summaries.
- Before calling it done, we tested everything: **111 automated checks, all passing**, plus two independent code reviews. Those found **19 problems** (some bundle several small ones). All of them are fixed.
- Six of the problems involved money or security. One was a mistake we made ourselves while tidying (the logo), and the tests caught it.
- The test site (test.calltrove.com) was checked file by file against the saved code: **93 of 93 files identical**.
- **None of this is live for customers yet.** It is saved on a work-in-progress branch. A step-by-step list of what must happen before launch is in section 5 and in the project folder (docs/PRODUCTION-DEPLOY-CHECKLIST.md).

1. Problems that involved money or security

These are the ones that mattered most. None of them reached a customer, because nothing has launched.

What went wrong	What it would have meant	What we did
Payments could be pinned on the wrong customer	When someone paid, the page told our server which account the payment was for, and the server believed it. A person with bad intentions could have named someone else's account and changed or cancelled that customer's subscription.	The server now hands the page a sealed, tamper-proof tag for the account. Anything that isn't sealed correctly is ignored. Tested with fake and copied tags.
A customer could be charged twice for usage	If the connection to the payment company dropped at the wrong moment, the system assumed nothing was charged and tried again an hour later. The charge may already have gone through.	After an unclear failure the system now stops and flags it for a person to check. It only retries when the payment company clearly says no.
Someone could pay using another person's email	Anyone could sign up with an email address they don't own. The real owner would later be told that address is taken.	You must now type a 6-digit code emailed to that address before you can reach payment. If someone pays without confirming, no account is created and an alert is saved.

What went wrong	What it would have meant	What we did
A new sign-up could erase someone else's checkout	Signing up again with the same email deleted the earlier person's waiting checkout, so theirs stopped working.	Waiting sign-ups are no longer deleted by newer ones. Old unpaid ones are cleared after 7 days.
Paid, but no account, and nobody told	If two people paid for the same email, the second got nothing and the only trace was a line in a log.	It now writes an alert to the audit log so a person can refund or fix it.
Two logins that differ only by capital letters	'Bob' and 'bob' could both exist, so a login could open the wrong one.	Logins now ignore capital letters everywhere, and the database refuses duplicates.

2. Problems customers would have run into

What went wrong	What it would have meant	What we did
A typo in the password confirmation blocked sign-up for good	Type the confirmation wrong once, fix it, and the browser kept saying 'passwords don't match' and would not continue. Found in the final round of testing.	The old message now clears the moment either password is edited.
The site hung after sign-up (a 504 error)	The new code expected a new place in the database that did not exist yet, so every signed-in page crashed.	We applied the database update. The lesson is now step 5 in the launch checklist: always run the database update on deploy.
The payment form was squeezed into a narrow strip	Our own security settings blocked the payment company from sizing its form, so it fell back to a tiny one with a scrollbar.	We allowed that one thing on the three payment pages only. Everywhere else stays locked down. The form now fills the page.
A strange screen appeared after paying	For about ten seconds the payment company's own generic success message showed inside our page, then the page jumped to login.	We replace it right away with our own 'Payment received, setting up your account' screen. If you saw something different, send us a screenshot: we could not see inside the payment company's frame.
New customers saw errors before connecting GoHighLevel	The dashboard, Contacts and the Settings 'report' tab asked for call data that doesn't exist yet. Invisible to the eye, but they filled the browser's error log.	Those pages now check first and show a clear 'Connect your GoHighLevel account' message. No errors.
The test site's Sign in button went to the live site	The marketing page had the live address built in, so testers were sent to the stopped production site.	On the test site it now uses the test site's own login and shows a Sign up link. The live site is unchanged.

What went wrong	What it would have meant	What we did
The 'confirm your email' link claimed success even when it hadn't worked	In one case the link said 'confirmed' but nothing was saved, so password resets would never work for that person.	That link was replaced by the code step, which tells the truth.
Small rough edges in the new email-code step	A wrong code showed a red error in the browser console. Double-clicking showed 'expired'. If our email provider was down, the person lost one of their six codes. The wait timer was wrong.	All four fixed and covered by tests.
Wrong labels	A button said 'Create account' before payment. A field said 'Business or agency name'. A leftover price note crowded the first screen.	Now 'Continue', 'Business name', and the note is gone (prices appear on the plan step).

3. Look and feel

What went wrong	What it would have meant	What we did
The logo was out of line	The phone was floating above the wordmark.	Aligned so the phone sits level with CallTrove on every page.
We broke the logo fix ourselves	While tidying old styling we accidentally deleted the logo rule. The tests caught it.	Restored, and the test suite now checks it so it can't quietly disappear again.
Green isn't a brand color	We had used green for checkmarks, finished steps and success messages.	Replaced with terracotta. The existing greens inside the dashboard were left alone, as you asked.
A login message was hard to read in dark mode	Dark-green text on a dark background.	It now follows the light and dark themes.

4. How we tested

- **111 automated checks** in 10 groups: every public page at three screen sizes, the sign-up steps, the email code, payment and account creation, security attacks, the payment gate, new and existing customers, usage billing, and look and feel.
- **Two independent code reviews** by a fresh reviewer who did not see our reasoning. Their findings were checked one by one. A few were wrong or didn't apply, and we said so; the real ones are fixed above.
- **The test site was compared with the saved code**, file by file: 93 files, no differences.
- **The tests can be re-run** any time (the file tests/run.sh in the project) and are saved with the code.

What we could not test here

- The real Paddle payment form and its success screen. We tested with a stand-in. Your own test payments on the test site covered the real thing.
- Real emails. The test site has no email key, so the email check is switched off there. It was tested with a fake mailbox.
- Real GoHighLevel connections.

Things still open

- **The 'page with code on it'** you saw after paying. Our server shows nothing odd in that window, so it was most likely inside Paddle's own frame. Send a screenshot if it shows up again.
- **Overdue payments** keep the app open but pause transcripts and AI summaries. A cancelled subscription locks everything. That was our call; tell us if you want overdue to lock the app too.
- **HIPAA plan storage:** a HIPAA customer is promised 150 GB, but an operator must switch their storage tier by hand (following your HIPAA checklist). Until then they get the standard 100 GB.
- **Legal:** the BAA wording (which now matches the form: name and job title) should get a lawyer's look before launch.
- **Security housekeeping:** the Paddle test key was pasted into a chat during testing. Replace it.

5. What is waiting to go live

Nothing below is on the live site. Production is stopped, and the new code is on a work-in-progress branch (not yet merged). The full, tickable list is saved in the project at **docs/PRODUCTION-DEPLOY-CHECKLIST.md**.

Before launch (you)

- Get the **live Paddle account approved** (Paddle reviews the website, so calltrove.com must be up).
- In live Paddle: recreate the product with a **\$25/month** price and a **\$30/month** price.
- In live Paddle: set the **default payment link to <https://app.calltrove.com>**, add the **webhook** (<https://app.calltrove.com/webhooks/paddle>, all subscription events), set the button color to **#B1502F** and turn off discount codes.
- Set up **email sending** for production (Resend key and sender). The sign-up email check needs it.
- Have the BAA wording reviewed. Decide when to show the Sign up link on the public site.
- Replace the Paddle test key.

Launch day (we do this together)

- Start the database first, then the server. Take a database snapshot.
- Merge the work to the main code and deploy it. Install the new Paddle package.
- Add the live Paddle and email settings to the server. **Leave the test-only 'skip email check' setting OFF.**
- **Run the database update** (never skip this one).
- Restart, then do a real sign-up with a real card and refund it. Check the webhook shows success in Paddle, existing customers see their data as before, and a new customer sees the Connect GoHighLevel message.

After launch

- Check the audit log for 'paid but no account' alerts, and the server log for usage charges marked 'unknown outcome'.
- First month-end usage charges go out on the 1st, and any time a customer's unpaid usage reaches \$20.
- Switch each HIPAA customer's storage tier by hand after the HIPAA checklist.

6. The test site

The test site (test.calltrove.com) has been **turned off** to save money (the server named calltrove-test in AWS is stopped, not deleted). Everything on it matches the saved code. To use it again, start that server, or ask us to; its address stays the same. It has no email key, so it runs with the email check switched off. Note that AWS still charges a few dollars a month for the fixed address while the server is stopped.